COMPLIANCE

Information Security Policy

How we protect customer data and our systems: data handling, accounts, devices, phishing, physical security and incidents.

Version	Owner	Effective from	Next review	Applies to
4.0	Sam Okafor, Security Lead	1 Jul 2026	1 Jul 2027	All employees and contractors

Mandatory. Complete security awareness training within your first 14 days and once a year after that. Phishing simulations run every quarter. Completion is recorded for our SOC 2, ISO 27001 and ISO 42001 audits.

1. Data classification

Class	Examples	Rules
Public	Website, public docs, published model cards	Share freely.
Internal	Roadmaps, this handbook, internal metrics	Share inside Mubit only.
Confidential	Customer contracts, pricing, financials, customer configurations	Need-to-know only. Never on personal devices.
Restricted	Customer traces and prompts, credentials, unreleased model weights	Approved systems only. Never exported, never pasted into AI tools, never in dev environments.

2. Accounts and passwords

- Use multi-factor authentication on every work account. Use a hardware key or an authenticator app; SMS codes are not allowed.
- Store every work password in the company 1Password vault. Never reuse a password.
- Never share your account or MFA codes with anyone, including IT. IT will never ask for them.

3. Devices

- Disk encryption must stay on. Your screen auto-locks after 5 minutes.
- Lock your screen whenever you leave your desk.
- Install operating system updates within 7 days of release.
- Do not access Confidential or Restricted data from personal devices.

4. Phishing

Most attacks start with a message. Treat any message that pushes you to act fast, outside the usual process, as suspicious.

Warning signs

- Urgency or pressure: "the CEO needs this in 10 minutes".
- A sender domain that is close to ours but not ours, such as mubit-ai.co or rnubit.ai.
- Unexpected attachments, QR codes, or links to log-in pages.

- Requests to change bank details, buy gift cards, or skip an approval.

What to do

1. Do not click links, open attachments or reply.
2. Use the Report phish button in Gmail, or forward the message to phish@mubit.example, and post in #security.
3. If you already clicked or entered credentials, report it in #security-incidents within 15 minutes and change your password. Reporting quickly matters more than anything else, and nobody is blamed for reporting.

Payment and bank detail changes

Verify every request to change bank details or make an urgent payment by calling the person on a number you already have. Never use a phone number from the message itself.

5. Physical security

- Badge in every time you enter. Do not hold the door for people you do not recognise: this is tailgating.
- If someone tries to follow you in, politely ask who they are visiting and send them to reception.
- Visitors sign in at reception, wear a visitor badge and are escorted at all times.
- Clear your desk at the end of the day. Confidential papers go in the locked shredding bin.

6. Production and customer data access

- Access follows least privilege. Production access is just-in-time, approved by the on-call lead, logged, and expires after 4 hours.
- Never copy customer data into development or test environments. Use synthetic fixtures.

7. Reporting incidents

Report any suspected incident, such as a lost laptop, a leaked secret or data sent to the wrong person, within 1 hour in #security-incidents or to security@mubit.example. When in doubt, report it.